

WARDEN

Nothing runs without a verdict.

```
$ npm install expres █
```



The package is the payload.

48,244

CVES PUBLISHED
IN 2025

454,648

MALICIOUS PACKAGES
FOUND IN 2025

205,474

FAKE PACKAGE
NAMES GENERATED

Resolve, verify, diff, scan, score: before anything runs.

● ● ● ~/project

▶▶ SKIP ● LIVE

```
$ warden check acme-http@1.0.1
resolving acme-http@1.0.1
✓ integrity verified    sha512
! release diff         postinstall added
! provenance           attestation removed
! code                 process.env → raw IP
BLOCK acme-http@1.0.1  risk 100 / 100
exit 20 · install never started
```

● BLOCKED BEFORE ANY SCRIPT RAN

A real dependency graph takes minutes. Warden says what it is doing, the whole time.

● ● ● ~/project

▶▶ SKIP ● LIVE

```
$ warden plan -- npm install @fastify/jwt
✓ resolving the prospective dependency graph · 70    8.3s
✓ vetting 60 changed packages · 60/60    19.4s
Warden plan: npm install @fastify/jwt
  + 22 transitive packages · 1 carries a new install script
NEEDS_APPROVAL  ret@0.5.0 has a prepare script
every wait says what it is doing, on a terminal and in a log
```

The same gate, run backward across what's already installed.

```
● ● ● ~/project ▶▶ SKIP ● LIVE

$ wnpm doctor
auditing 3 direct dependencies against OSV advisories
high      acme-json@2.1.0  prototype pollution  (fixed in 2.1.4)
critical  acme-http@1.0.0  request smuggling    (fixed in 1.0.1)
BLOCK    acme-http@1.0.1  install-script added, exfiltration, provenance downgrade
UNFIXABLE acme-http: the official fix fails the supply-chain gate
verified  acme-json@2.1.4 · install ok · test ok · applied
1 of 2 issues fixed · exit 10
```

● THE OFFICIAL FIX GETS REJECTED WHEN THE RELEASE ITSELF IS COMPROMISED

Claims from the prompt, checked against the diff.

● ● ● ~/project

▶▶ SKIP

● LIVE

```
$ warden intent check
prompt "add rate limiting, keep the retry logic, log every rate-limited request"
3 claims extracted · 2 files changed
✓ delivered add rate limiting api-client.ts:1-39
✓ preserved retry logic untouched
✗ dropped log every rate-limited request no matching change
! scope creep pagination.ts, 55 lines, never requested
! hallucinated axios.instance.throttle, not exported by axios
BLOCK 3 findings
exit 20 · diff does not match the prompt
```

● FLAGS DRIFT BEFORE THE PR MERGES

One trust layer. Every workflow.

Every verb resolves to the same contract: allow, warn, or block.

check

vet a package

plan

decide the graph

apply

install with a receipt

install

vet, then install

ci

vet changed deps

doctor

audit & repair

intent

diff vs. prompt

policy

compile the rules

detect

map workspace

init

wire guardrails

fix

agent handoff

log

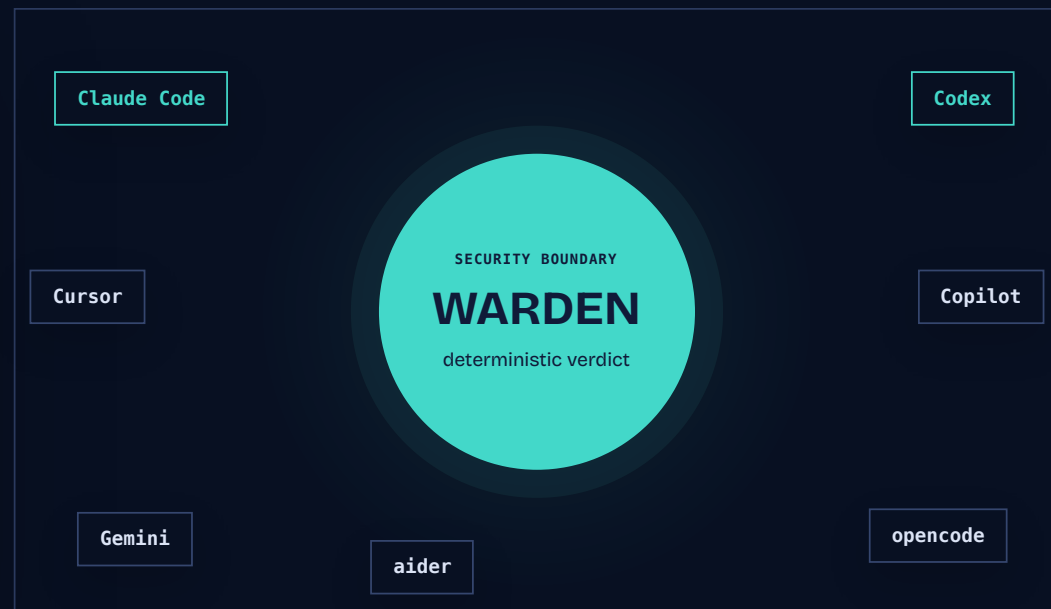
observe safely

shims for npm, pnpm, yarn, bun, npx, and bunx · pick one with `--npm`, `--pnpm`, `--yarn`, `--bun` · protect blocks, observe just records

Your agent gets evidence, a fix, and a finish line.

```
● ● ● structured handoff  >> SKIP  ● LIVE

$ warden fix
wrote .warden/handoff.json
finding   expres@0.0.5 · typosquat
evidence  1 edit from express · postinstall added
fix       replace expres with express
verify    warden ci --reporter agent
launch    codex exec "Read .warden/handoff.json..."
$ codex exec "Read .warden/handoff.json and apply the
fix"
updated   package.json · expres → express
$ warden ci --reporter agent
```



detect



handoff



fix



verify clean

Keep the workflow. Add the checkpoint.



Sources

01 CVE Program metrics

03 USENIX package hallucinations

02 Sonatype 2026 report

04 OSV advisory database

Figures checked July 14, 2026.